

ACTIVITÉ 3 – Comprendre les attaques Web (OWASP + CWE)

Objectifs pédagogiques

À la fin de cette activité, le stagiaire doit être capable de :

- Reconnaître une attaque à partir d'un scénario
- Expliquer simplement une vulnérabilité
- Proposer une solution basique
- Choisir un **CWE** à partir d'un tableau guidé
- Comprendre le lien avec le **OWASP Top 10**

CONSIGNE GÉNÉRALE

Répondre avec des phrases simples.

Pour le **CWE**, utiliser uniquement le tableau suivant.

TABLEAU DES CWE AUTORISÉS

CWE	Quand l'utiliser
CWE-89	Requête SQL manipulée (Injection SQL)
CWE-79	Script injecté dans une page web (XSS)
CWE-284	Accès non autorisé
CWE-287	Problème d'authentification
CWE-522	Mot de passe mal protégé
CWE-311	Données sensibles non chiffrées
CWE-319	Données envoyées en HTTP
CWE-798	Mot de passe par défaut ou dans le code
CWE-1104	Composant obsolète
CWE-16	Mauvaise configuration

PARTIE 1 — Compréhension du cours (5 points)

Question 1

Définir :

Qu'est-ce qu'une vulnérabilité d'application web ?

(Réponse en 2 lignes maximum)

Question 2

Compléter :

Élément	Réponse
OWASP	
OWASP Top 10	

Question 3

Donner un exemple d'attaque vu dans le cours.

PARTIE 2 — Tableau principal (8 points)

Consigne

Compléter le tableau suivant :

Attaque	Description	Scénario	Prévention	CWE
Injection SQL				
XSS				
Broken Access Control				
Cryptographic Failures				

Aide :

- Injection SQL → login
- XSS → champ web

PARTIE 3 — Identifier l'attaque (5 points)

Associer chaque scénario à :

- Une attaque OWASP
- Un CWE

Cas 1 : Un utilisateur entre du code SQL dans un formulaire de connexion.

Cas 2 : Un script JavaScript est exécuté dans le navigateur d'un utilisateur.

Cas 3 : Un utilisateur accède à un autre compte en modifiant l'URL.

Cas 4 : Un site envoie les données en HTTP.

Cas 5 : Un système utilise un mot de passe par défaut.

PARTIE 4 — Réflexion (2 points)

Pourquoi les vulnérabilités existent encore aujourd'hui ?